

CYBER SECURE SOLUTIONS

Réponse à une violation de données personnelles

Type: rapport_violation_donnees

Date: 3/30/2025
Référence: Sécurisation des données personnelles
Destinataire: Max

****RAPPORT DE VIOLATION DE DONNÉES PERSONNELLES****

****Date du rapport : ** 18 octobre 2023**

****Auteur : ** Vincent Terrier**

****Destinataire : ** Max**

****1. Contexte de l'incident****

Le 17 octobre 2023, à 14h25, une alerte automatique a été déclenchée par l'outil de monitoring des accès (SecureVault v3.8) indiquant une activité suspecte sur le système de gestion des données personnelles de l'entreprise. L'analyse préliminaire a révélé une possible exfiltration de données concernant un sous-ensemble de notre base client. Les données compromises incluraient :

- Noms complets
- Adresses e-mail
- Numéros de téléphone
- Dates de naissance

L'incident semble avoir affecté un segment de notre base résidant sur le serveur ****DB-PERS-02****, hébergé dans le cloud AWS (Amazon Web Services).

****2. Chronologie des événements****

- ****14h25**** : Alerte initiale générée par SecureVault. Tentative d'accès non autorisé détectée depuis une adresse IP située en dehors de nos zones géographiques habituelles (origine : 203.0.113.45, localisée en Asie).
- ****14h30**** : Les connexions suspectes ont été interrompues automatiquement par le firewall.
- ****14h45**** : Analyse initiale effectuée par l'équipe SOC (Security Operations Center), confirmant une probable extraction de données via des requêtes SQL inhabituelles. Les logs montrent des tentatives de "SQL Injection".
- ****15h10**** : Les administrateurs système ont isolé le serveur DB-PERS-02 pour empêcher toute activité supplémentaire.
- ****16h00**** : Découverte que l'accès initial pourrait provenir d'un compte utilisateur compromis avec des privilèges élevés (compte : 'admin_legacy').

****3. Évaluation technique****

****Système impacté : ****

- Serveur : DB-PERS-02
- Type de base : PostgreSQL v12.4
- Hébergement : AWS (instance EC2, région eu-west-1)
- Configuration réseau : VPN obligatoire pour l'accès interne, mais connexion administrateur compromise.

****Vulnérabilité suspectée : ****

- Utilisation de techniques de SQL Injection sur un endpoint API non sécurisé (endpoint : `/api/v1/userdata/export`).
- Failles dans les politiques de gestion des comptes administratifs, notamment l'utilisation d'un ancien compte "admin_legacy" non désactivé.

****Volume estimé des données exposées : ****

- Environ 12 500 enregistrements client.

****4. Implications potentielles****

La compromission des données personnelles peut entraîner :

- Des violations du RGPD (Règlement Général sur la Protection des Données), avec des amendes pouvant aller jusqu'à 4% du chiffre d'affaires annuel.
- Une perte de confiance des clients.
- Des risques accrus de phishing ou d'usurpation d'identité pour les individus concernés.

****5. Mesures immédiates prises****

- Isolation complète du serveur DB-PERS-02.
- Révocation des accès du compte compromis ('admin_legacy').
- Notification envoyée à l'équipe juridique pour évaluer les obligations de notification au régulateur (CNIL).
- Les logs pertinents ont été sauvegardés pour analyse approfondie.

****6. Recommandations pour enquête****

Bien que l'incident soit en cours d'investigation, voici les aspects à examiner :

- Analyse complète des logs du serveur DB-PERS-02 et des accès API.
- Vérification des configurations réseau et des règles de pare-feu.
- Identification des failles dans la gestion des comptes utilisateurs.
- Évaluation des contrôles de sécurité sur l'endpoint `/api/v1/userdata/export`.

****Contact pour suivi : **** Vincent Terrier (Responsable Sécurité Informatique)

****Email : **** vincent.terrier@entreprise.com

****Téléphone : **** +33 6 12 34 56 78

****Note au destinataire :**** Ce rapport ne contient pas de solutions. Il est essentiel de collaborer avec les équipes techniques et juridiques pour déterminer les actions nécessaires.
